UNIVERSIDAD NACIONAL DEL ALTIPLANO

FACULTAD DE INGENIERÍA MECÁNICA ELÉCTRICA Y DE SISTEMAS

Plan Integral de Ciberseguridad Institucional

Caso de Aplicación: Universidad Nacional del Altiplano de Puno (UNAP)

PRESENTADO POR:
QUISPE CHATA CARLOS DAVID

DOCENTE:
TICONA YANQUI FIDEL ERNESTO

SEMESTRE: IX

PUNO – 2026

ÍNDICE GENERAL

Sección Preliminar: Declaración Ética, Marco Legal y Metodología 1

1 Datos Generales de la Entidad 4

1.1 Ficha Técnica Institucional 4
1.2 Ámbito de Aplicación y Cobertura Operativa 4
1.3 Estructura Orgánica y Roles de Seguridad 5

2 Introducción 6

2.1 Contexto y Relevancia Institucional 6
2.2 Caracterización de la Superficie Expuesta Universitaria 6
2.3 Ineficacia del Perímetro Tradicional y Nuevas Amenazas 6
2.4 Enfoque Holístico de Ciberseguridad y Gobernanza 6

3 Finalidad y Objetivos 8

3.1 Finalidad 8
3.2 Objetivos del Plan 9
3.2.1 Objetivo General 9
3.2.2 Objetivos Específicos 9

4 Alcance del Plan 10

4.1 Factor Humano y Organizacional 10
4.2 Infraestructura Tecnológica y Hardware 11
4.3 Redes y Comunicaciones 11
4.4 Aplicaciones y Sistemas de Información 12
4.5 Bases de Datos y Almacenamiento de Información 12
4.6 Correo Institucional, Mensajería e Identidad Federada 12
4.7 Servicios en la Nube y Proveedores Tecnológicos 12

5 Inventario y Clasificación de Activos 13

5.1 Metodología de Identificación y Valoración 13
5.2 Criterio de Clasificación Institucional 14
5.3 Matriz Consolidada de Clasificación de Activos (UNAP) 14
5.4 Conclusiones del Inventario de Activos y Brechas Identificadas 16

6 Análisis de Amenazas mediante STRIDE 17

6.1 Metodología de Modelado STRIDE 17

6.2 Selección y Alcance del Sistema Objetivo 18
6.3 Diagrama de Flujo de Datos (DFD) y Límites de Confianza 18
6.3.1 Elementos del DFD Nivel 1 18
6.3.2 Esquema Arquitectónico del DFD Nivel 1 19
6.4 Evaluación de Riesgos (Criterio DREAD Adaptado) 20
6.5 Matriz de Análisis STRIDE del Sistema de Matrícula (UNAP) 20
6.6 Procedimiento de Implementación de Controles Mitigadores 22
6.6.1 A. Hardening Inmediato en Servidor Web Nginx (P-01) 22
6.6.2 B. Aseguramiento del Manejo de Sesiones en ASP.NET Core (P-02 / D-01) 22
6.6.3 C. Control Transaccional en Base de Datos (P-04 / D-02) 24

7 Inteligencia de Amenazas (Threat Intelligence) 25

7.1 Fundamentación y Objetivos de la Vigilancia Institucional 25
7.2 Ciclo Operativo de Threat Intelligence en la UNAP 26
7.3 Taxonomía de Indicadores de Compromiso (Pirámide del Dolor) 27
7.4 Producto Operativo: Boletín de Inteligencia de Amenazas 28
7.5 Procedimiento de Actualización y Gobernanza 29

8 Análisis con MITRE ATT&CK 31

8.1 Estudio de TTPs Aplicables a la Superficie de la UNAP 31
8.2 Matriz MITRE ATT&CK Institucional y Brechas de Visibilidad 32
8.3 Regla de Detección SIEM (Wazuh / Sysmon) 33

9 Análisis mediante Cyber Kill Chain 34

9.1 Modelado del Ciclo Lineal de Intrusión 34
9.2 Puntos de Quiebre Defensivo y Controles de Interrupción 34

10 Implementación de Arquitectura Zero Trust 36

10.1 Pilares de la Arquitectura Zero Trust en la UNAP 36
10.2 Matriz de Roles, Usuarios y Permisos (RBAC / Zero Trust) 36

11 Marco General de Ciberseguridad NIST CSF 2.0 38

11.1 Las Seis Funciones Fundamentales del NIST CSF 2.0 en la UNAP 38
11.2 Matriz NIST CSF 2.0 de la UNAP 38

12 Controles Técnicos de Seguridad 40

12.1 Catálogo de Especificación Técnica de Controles 40
12.2 Configuración de Endurecimiento Web en Servidores Nginx 40

13 Gestión y Respuesta a Incidentes 42

13.1 Procedimiento Operativo Estándar 42
13.2 Canales Institucionales de Notificación Rápida 42
13.3 Clasificación de Incidentes por Tipo de Amenaza 43

14 Capacitación y Concientización 44

14.1 Campaña Permanente de Concientización 44
14.2 Simulaciones Semestrales de Phishing Controlado 44
14.3 Módulos de Formación Especializada para Personal Técnico 44

15 Indicadores de Cumplimiento (Métricas y KPIs) 45

15.1 Cuadro de Mando de Métricas de Ciberseguridad 45

Anexos: Evidencias y Documentación de Soporte 46

DECLARACIÓN ÉTICA, MARCO LEGAL Y METODOLOGÍA

Sección Preliminar: Marco de Integración Metodológica Institucional

NIST CSF 2.0 (Gestión) $\longrightarrow$ **STRIDE** (Amenazas) $\longrightarrow$ **MITRE ATT&CK** (TTPs)
$\longrightarrow$ **Threat Intelligence** (Vigilancia) $\longrightarrow$ **Cyber Kill Chain** (Fases) $\longrightarrow$ **Zero Trust** (Controles)

1 Declaración Ética y de No Intrusión

El presente documento, titulado **"Plan de Ciberseguridad Institucional de la Universidad Nacional del Altiplano de Puno (UNAP)"**, ha sido formulado exclusivamente con fines de investigación académica, auditoría defensiva (*Blue Team*) y diseño de arquitectura de seguridad (*Security by Design*).

Los autores/evaluadores declaran bajo juramento de integridad profesional y académica:

- **Ausencia de Pruebas Intrusivas:** En ninguna etapa de la elaboración de este plan se llevaron a cabo análisis de penetración activos (*Pentesting*), pruebas de denegación de servicio (DoS/DDoS), inyecciones de código malicioso, ataques de fuerza bruta contra paneles autenticados, ni explotación de vulnerabilidades en los sistemas de información institucionales.
- **Preservación de la Continuidad Operativa:** Ninguna de las consultas realizadas generó alteración, interrupción, degradación de rendimiento o indisponibilidad en los servicios informáticos de la UNAP.
- **Respeto a la Privacidad de los Datos:** No se accedió, extrajo, manipuló ni divulgó información personal, financiera o académica protegida perteneciente a estudiantes, docentes, personal administrativo o autoridades de la universidad. El acceso a las interfaces analizadas se efectuó dentro del marco de sesiones ordinarias y legítimas provistas a los miembros de la comunidad universitaria.
- **Finalidad Propositiva y Mitigadora:** Los hallazgos y evidencias recopilados tienen el único propósito de justificar técnicamente la necesidad de implementar controles preventivos bajo el marco NIST CSF 2.0, mitigar amenazas modeladas con STRIDE, mapear tácticas adversarias en MITRE ATT&CK e implementar un modelo de Confianza Cero (*Zero Trust*) que eleve la postura de ciberseguridad de la UNAP.

2 Marco Legal Aplicable en el Estado Peruano

El desarrollo de este plan y la justificación de los controles técnicos se fundamentan en el marco normativo nacional vigente en materia de gobernanza digital, seguridad de la información y delitos informáticos:

- **Ley N° 30096 (Ley de Delitos Informáticos) y su modificatoria Ley N° 30171:** La metodología empleada respeta irrestrictamente los artículos referidos al acceso ilícito (Art. 2), atentado a la integridad de datos y sistemas informáticos (Arts. 3 y 4) y fraude informático (Art. 8). Al no existir intrusión ni vulneración de medidas de seguridad perimetral, la recolección de telemetría pasiva no transgrede esta ley.
- **Decreto de Urgencia N° 006-2020 (Decreto de Urgencia que crea el Sistema Nacional de Transformación Digital):** Establece como deber de todas las entidades públicas peruanas, incluidas las universidades nacionales, la implementación de un Marco de Seguridad y Confianza Digital que proteja los activos de información del Estado.
- **Decreto Supremo N° 029-2021-PCM (Reglamento del Decreto Legislativo N° 1412, Ley de Gobierno Digital):** Dispone lineamientos mandatorios para la gestión de riesgos de seguridad digital en las plataformas de servicios digitales públicos.
- **Ley N° 29733 (Ley de Protección de Datos Personales) y su Reglamento (D.S. N° 003-2013-JUS):** Regula el tratamiento y la confidencialidad de los bancos de datos que albergan identificadores personales de estudiantes y trabajadores en los sistemas de matrícula y recursos humanos de la UNAP.
- **Resoluciones y Directivas de la Secretaría de Gobierno y Transformación Digital (SGTD - PCM):** En su calidad de ente rector nacional en ciberseguridad y coordinador del Centro Nacional de Seguridad Digital (CSIRT Nacional).

3 Metodología de Evaluación y Recolección de Evidencias

Para la identificación de brechas y sustento del análisis de amenazas, se utilizó estrictamente una metodología de evaluación pasiva de fuentes abiertas (OSINT) e inspección de cliente en comunicaciones estándar, desglosada en los siguientes procedimientos:

A Inteligencia de Fuentes Abiertas y Consulta DNS Pasiva (OSINT)

- **Descubrimiento de Superficie Expuesta:** Se consultaron los registros públicos de Transparencia de Certificados SSL/TLS (*Certificate Transparency Logs* vía `crt.sh`), identificando la existencia de más de un centenar de subdominios registrados bajo la zona `*.unap.edu.pe` sin interactuar directamente con los hosts objetivo.
- **Auditoría de Registros de Correo Institucional:** Se ejecutaron peticiones estándar de resolución de nombres DNS (tipo TXT) mediante la herramienta de diagnóstico de sistemas operativos `nslookup` apuntando a servidores DNS públicos, con el fin de evaluar la postura de los registros de autenticación de correo:
  - Verificación de la directiva SPF (*Sender Policy Framework*) en el dominio raíz `unap.edu.pe`.
  - Verificación de la presencia o ausencia de políticas de alineación DMARC (*Domain-based Message Authentication, Reporting, and Conformance*) en el nodo `_dmarc.unap.edu.pe`.

B Inspección Pasiva del Lado del Cliente (Client-Side Inspection)

- **Análisis de Cabeceras HTTP de Respuesta:** Mediante las herramientas de desarrollo web del navegador (DevTools - F12 / RFC 7230) en el marco de una navegación regular autorizada hacia los portales `https://matricula.unap.edu.pe` y `https://campus.unap.edu.pe`, se examinaron los encabezados enviados de forma pública por los servidores web:
  - Exposición de metadatos de software y versión en el encabezado `Server` (`nginx/1.16.1`).
  - Comprobación del estado de la directiva de transporte seguro HSTS (`Strict-Transport-Security`).
  - Inspección de cabeceras de defensa contra ataques visuales y de contexto (`X-Frame-Options`, `Content-Security-Policy`, `X-Content-Type-Options`).
- **Inspección de Atributos de Almacenamiento de Sesión:** Revisión de las banderas de seguridad asignadas a las cookies de autenticación generadas por el entorno de desarrollo (.NET Core: `.AspNetCore.Cookies`, `CookieTempDataProvider`) para evaluar la presencia de los atributos `HttpOnly`, `Secure` y `SameSite`.

C Modelado de Amenazas y Simulación Teórica (Tabletop Simulation)

La articulación de las amenazas no provino de incidentes forzados en producción, sino del cruce sistemático entre las vulnerabilidades de configuración verificadas pasivamente y las matrices estandarizadas de la industria (STRIDE de Microsoft, la taxonomía de técnicas de MITRE ATT&CK Enterprise v14 y las 7 fases de intrusión de la Cyber Kill Chain de Lockheed Martin).

Nota de Rigor Académico: Con este marco queda formalmente establecida la rigurosidad técnica, ética y legal del documento frente a cualquier comisión evaluadora o autoridad universitaria.

1 DATOS GENERALES DE LA ENTIDAD

En este capítulo se formalizan los datos institucionales de la entidad universitaria, las dependencias responsables del gobierno y administración de la seguridad digital, el marco temporal de vigencia y el alcance operativo del plan.

Sec 1.1 Ficha Técnica Institucional

Campo	Detalle Institucional
Nombre de la Entidad	Universidad Nacional del Altiplano de Puno (UNAP).
Unidad Responsable	Oficina de Tecnologías de la Información (OTI) — Unidad de Redes, Comunicaciones y Seguridad Informática.
Responsable del Plan	▪ Jefe de la Oficina de Tecnologías de la Información (OTI). ▪ Oficial de Seguridad de la Información (CISO Institucional / Delegado de Seguridad Digital).
Periodo de Vigencia	2026 – 2027 (vigencia de doce meses, sujeta a evaluación semestral de madurez y revisión anual obligatoria).
Fecha de Aprobación	Octubre de 2026 (conforme a los mecanismos de aprobación institucional mediante Resolución Rectoral).
Ámbito de Aplicación	Sede Central (Av. Floral N° 1153), 20 Facultades, 36 Escuelas Profesionales, Posgrado, Órganos de Alta Dirección y Data Center OTI.

Sec 1.2 Ámbito de Aplicación y Cobertura Operativa

El alcance del presente plan abarca la totalidad de las dependencias físicas, académicas, directivas e infraestructuras de datos de la institución:

- **Sede Central y Campus Universitario:** Ciudad Universitaria ubicada en la Av. Floral N° 1153, Puno, incluyendo edificios administrativos, aulas magnas y laboratorios centrales.
- **Dependencias Académicas:** 20 Facultades, 36 Escuelas Profesionales, la Escuela de Posgrado y los Centros de Producción de Bienes y Servicios universitarios.

- **Órganos de Alta Dirección y Apoyo Administrativo:** Rectorado, Vicerrectorado Académico (VRA), Vicerrectorado de Investigación (VRI), Dirección General de Administración (DGA), Dirección de Registro y Matrícula, y Secretaría General.
- **Infraestructura de Datos:** Centro de Procesamiento de Datos (Data Center OTI), nodos perimetrales de telecomunicaciones, plataformas en nube institucional y servicios web federados.

Sec 1.3 Estructura Orgánica y Roles de Seguridad

La ejecución y supervisión del presente plan involucra a los siguientes actores clave de la gobernanza universitaria:

1. **Alta Dirección (Rectorado y Vicerrectorados):** Aprobación presupuestal, respaldo normativo y asignación de prioridades estratégicas para el fortalecimiento de la infraestructura digital.
2. **Oficina de Tecnologías de la Información (OTI):** Conducción técnica general, administración del Data Center institucional y despliegue de las políticas de seguridad.
3. **Unidad de Redes y Seguridad Informática / CSIRT-UNAP:** Monitoreo continuo de eventos de seguridad, gestión perimetral de firewalls, sistemas de detección y respuesta inmediata ante incidentes cibernéticos.

2 INTRODUCCIÓN

Sec 2.1 Contexto y Relevancia Institucional

La Universidad Nacional del Altiplano de Puno custodia, gestiona y transfiere permanentemente el patrimonio digital, académico, científico y administrativo de más de 20,000 usuarios activos entre estudiantes, investigadores, plana docente y personal directivo-administrativo. La progresiva consolidación de servicios digitales (como el Sistema de Matrícula en línea, la plataforma de Campus Virtual Moodle, el Sistema de Trámite Documentario SITRAD y los repositorios institucionales de investigación) ha desplazado los límites del campus físico hacia un ecosistema hiperconectado, distribuido y expuesto permanentemente a Internet.

Sec 2.2 Caracterización de la Superficie Expuesta Universitaria

Sin embargo, esta apertura operativa ha expandido correlativamente la superficie de exposición institucional. Las auditorías pasivas y de reconocimiento externo realizadas sobre el dominio `unap.edu.pe` constatan una arquitectura heterogénea donde coexisten más de un centenar de subdominios registrados, servidores web con capas de proxy inverso desactualizadas (como `nginx/1.16.1` en el entorno de matrícula), mecanismos de transporte seguro sin directivas estrictas de mitigación frente a interceptaciones (ausencia de `Strict-Transport-Security` — HSTS) y una vulnerable postura de confianza en la mensajería institucional evidenciada por la inexistencia de directivas DMARC (`NXDOMAIN`) y mecanismos permisivos de Sender Policy Framework (SPF: `~all`).

Sec 2.3 Ineficacia del Perímetro Tradicional y Nuevas Amenazas

En este escenario, el modelo clásico de “seguridad perimetral” —basado en la premisa ingenua de que los recursos dentro de la red interna son confiables por defecto— resulta completamente ineficaz. La sofisticación de las amenazas actuales, tales como campañas de Spear-Phishing dirigidas al personal administrativo en ventanas críticas de matrícula, infecciones por ransomware que paralizan servidores de gestión pública, y técnicas de movimiento lateral basadas en el abuso de identidades válidas, exige la formulación de una estrategia integral, moderna y resiliente.

Sec 2.4 Enfoque Holístico de Ciberseguridad y Gobernanza

El presente Plan de Ciberseguridad Institucional adopta un enfoque multifacético y holístico: acoge al estándar NIST Cybersecurity Framework (CSF) 2.0 como el marco sombrilla de gobernanza; integra el modelado temprano

de amenazas mediante STRIDE para los flujos de software; correlaciona los comportamientos y tácticas adversarias observadas con la taxonomía MITRE ATT&CK Enterprise; incorpora la vigilancia contextual de Threat Intelligence; diseña barreras de contención escalonadas mediante la Cyber Kill Chain; y materializa controles estrictos bajo la doctrina de Zero Trust (*"Nunca confiar, siempre verificar de manera explícita y asumir la brecha"*). Con ello, la UNAP alinea su gestión tecnológica con las exigencias del Decreto de Urgencia N° 006-2020 y asegura la continuidad irrestricta de su servicio educativo superior.

3 FINALIDAD Y OBJETIVOS

En este capítulo se define el propósito estratégico del plan de seguridad digital y los objetivos medibles formulados para la UNAP.

Sec 3.1 Finalidad

La finalidad del presente Plan Institucional de Ciberseguridad es establecer, normar y articular un conjunto coordinado de medidas técnicas, organizacionales, normativas y procedimentales orientadas a prevenir, identificar, proteger, detectar, responder y recuperarse eficazmente frente a incidentes, amenazas y ataques informáticos que atenten contra la confidencialidad, integridad y disponibilidad del ecosistema tecnológico de la Universidad Nacional del Altiplano de Puno.

Para alcanzar dicha finalidad, el plan formaliza una arquitectura de defensa en profundidad mediante la sinergia de marcos y metodologías de referencia internacional:

- **Gobernanza Estratégica (NIST CSF 2.0):** Institucionalizar la ciberseguridad a nivel transversal en la universidad, estructurando la toma de decisiones, la asignación de recursos y la gestión integral de riesgos tecnológicos dentro de las seis funciones directivas: Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar.
- **Modelado Preventivo de Software (STRIDE):** Analizar y mitigar sistemáticamente los vectores de Suplantación (*Spoofing*), Manipulación (*Tampering*), Repudio (*Repudiation*), Fuga de Información (*Information Disclosure*), Denegación de Servicio (*Denial of Service*) y Elevación de Privilegios (*Elevation of Privilege*) en las aplicaciones críticas desarrolladas y operadas por la OTI (con especial énfasis en el flujo `matricula.unap.edu.pe`).
- **Vigilancia Proactiva (Threat Intelligence):** Monitorizar de forma continua indicadores de compromiso (IoCs), registros de suplantación de dominio (*typosquatting*), tácticas dirigidas contra el sector público peruano y vulnerabilidades de día cero para anticiparse a los vectores de intrusión.
- **Caracterización Técnica del Adversario (MITRE ATT&CK):** Mapear el comportamiento real y las tácticas, técnicas y procedimientos (TTPs) de los atacantes, habilitando capacidades analíticas en registros de auditoría y telemetría de red para transformar los incidentes en reglas de detección temprana en herramientas SIEM.
- **Ruptura del Vector de Intrusión (Cyber Kill Chain):** Diseñar controles específicos y puntos de quiebre defensivo en cada uno de los siete eslabones lineales del ataque, impidiendo que una amenaza en fase de reconocimiento o entrega (como el phishing facilitado por la ausencia de DMARC) culmine en la explotación o el secuestro de información sensible.
- **Controles Operativos Estrictos (Zero Trust Architecture):** Reemplazar la confianza implícita por una verificación continua y granular sobre identidades (MFA obligatorio), dispositivos de acceso, segmentación lógica de redes (VLANs), aplicaciones web blindadas y cifrado mandatorio de datos académicos y financieros, tanto en reposo como en tránsito.

Sec 3.2 Objetivos del Plan

3.2.1 Objetivo General

Fortalecer de forma integral la postura de seguridad de la información y la resiliencia operativa de la Universidad Nacional del Altiplano de Puno (UNAP), mediante la identificación rigurosa de activos críticos, el modelado sistemático de amenazas, la implementación de controles defensivos bajo el estándar de Confianza Cero (Zero Trust) y el establecimiento de capacidades institucionales estandarizadas de detección, respuesta y recuperación continua articuladas bajo el marco NIST CSF 2.0.

3.2.2 Objetivos Específicos

1. **Identificar y clasificar los activos de información:** Catalogar exhaustivamente el 100 % de los recursos tecnológicos, servidores, bases de datos, redes y servicios web asociados al dominio `unap.edu.pe`, estratificando su nivel de criticidad (Crítico, Alto, Medio, Bajo) conforme al impacto sobre la continuidad del servicio educativo y la confidencialidad de los datos.
2. **Determinar amenazas y vulnerabilidades arquitectónicas:** Ejecutar el modelado preventivo de amenazas mediante la metodología STRIDE sobre los sistemas críticos de la universidad (priorizando el flujo de matrícula y campus virtual), identificando debilidades de configuración, obsolescencia de software (como `nginx/1.16.1`) y ausencia de directivas de protección en el transporte (`Strict-Transport-Security`).
3. **Analizar y correlacionar las técnicas empleadas por atacantes:** Caracterizar el comportamiento potencial de ciberadversarios en el contexto universitario mediante la matriz MITRE ATT&CK Enterprise, traduciendo las técnicas y procedimientos observados en reglas formales de visibilidad, auditoría y monitoreo de eventos.
4. **Detectar amenazas reales mediante inteligencia proactiva:** Institucionalizar un flujo operativo de Threat Intelligence para monitorizar activamente campañas de Spear-Phishing, registros fraudulentos de dominios (*typosquatting*), abuso de la reputación institucional derivado de la ausencia de DMARC y explotación de vulnerabilidades conocidas (CVEs).
5. **Implementar controles preventivos y perimetrales:** Desplegar mecanismos de mitigación perimetral (Web Application Firewall - WAF, inspección de cabeceras, políticas DNS estrictas SPF: `-all` y DMARC: `p=reject`) y capacidades de protección en estaciones de trabajo y servidores mediante soluciones EDR centralizadas.
6. **Fortalecer el gobierno de identidades y el control de accesos:** Implementar la directriz de Autenticación Multifactor (MFA) obligatoria para personal administrativo, directivo y docente, combinada con políticas de privilegios mínimos (*Principle of Least Privilege*) y asignación estricta de roles (RBAC) en las plataformas académicas.
7. **Reducir los riesgos de exposición y fuga de datos personales:** Blindar los canales de transmisión y repositorios que albergan calificaciones, historiales académicos y datos de identificación personal (DNI, registros biométricos), garantizando el cumplimiento irrestricto de la Ley N° 29733 (Ley de Protección de Datos Personales).
8. **Mejorar la capacidad de respuesta y resiliencia ante incidentes:** Formalizar el Equipo de Respuesta a Incidentes de Seguridad Digital de la UNAP (CSIRT-UNAP), definiendo procedimientos operativos estandarizados (*Playbooks*) para minimizar los tiempos medios de detección (MTTD) y contención (MTTR), asegurando la restauración íntegra de servicios mediante copias de seguridad inmutables (estrategia 3-2-1).

4 ALCANCE DEL PLAN

El presente Plan Institucional de Ciberseguridad es de aplicación obligatoria, transversal y vinculante para todas las dependencias académicas, de investigación, administrativas y operativas de la Universidad Nacional del Altiplano de Puno.

Su ámbito de cobertura se desglosa en los siguientes dominios clave de gobernanza y protección tecnológica:

MATRIZ SINTÉTICA DE ALCANCE INSTITUCIONAL		
Factor Humano	**Infraestructura**	**Lógica y Datos**
▪ Estudiantes ▪ Plana Docente ▪ Administrativos ▪ Terceros y Soporte	▪ Data Center OTI ▪ Estaciones Administrativas ▪ Labs de Cómputo ▪ Core de Red y WAN	▪ Apps Web (Matrícula/Campus) ▪ Bases de Datos (PostgreSQL/SQL) ▪ Correo (`@unap.edu.pe`) ▪ Servicios Cloud y Repositorio

Sec 4.1 Factor Humano y Organizacional

- **Comunidad Estudiantil:** Más de 19,000 alumnos matriculados en programas de pregrado, posgrado y segunda especialidad que hacen uso de credenciales de acceso a portales institucionales.
- **Plana Docente e Investigadores:** Profesores nombrados y contratados con facultades de registro de evaluaciones, gestión curricular e investigación en laboratorios.
- **Personal Administrativo y Directivo:** Autoridades universitarias (Rectorado, Decanatos), personal de tesorería, recaudación, recursos humanos, mesa de partes y logística que gestiona información clasificada y flujos financieros.
- **Proveedores y Contratistas Externos:** Empresas y consultores que brindan servicios de desarrollo de software, mantenimiento de fibra óptica, soporte de hardware o licenciamiento institucional.

Sec 4.2 Infraestructura Tecnológica y Hardware

- **Centro de Procesamiento de Datos (Data Center OTI):** Todos los servidores físicos, chasis blade, sistemas de almacenamiento masivo (NAS/SAN), gabinetes de comunicaciones y sistemas de respaldo energético (UPS/Grupo electrógeno) ubicados en el campus central (Av. Floral).
- **Entornos de Virtualización:** Nodos hipervisores (VMware ESXi, Proxmox, Hyper-V) y contenedores donde se ejecutan los servicios centrales de la universidad.
- **Estaciones de Trabajo Institucionales:** Computadoras de escritorio y portátiles asignadas a oficinas administrativas, decanatos y dependencias funcionales de la universidad.
- **Laboratorios de Cómputo Académicos:** Toda la infraestructura de estaciones de trabajo ubicadas en las 20 facultades destinadas a prácticas de pregrado y posgrado.

Sec 4.3 Redes y Comunicaciones

- **Núcleo de Red (Core Network):** Switches de capa de distribución y núcleo, routers de borde y enlaces troncales de fibra óptica interfacultades en la Ciudad Universitaria.
- **Comunicaciones Inalámbricas (WLAN):** Puntos de acceso (*Access Points*) y controladores Wi-Fi desplegados en áreas comunes, facultades y pabellones administrativos (segmentando el tráfico de invitados del tráfico académico).
- **Perímetro y Conectividad Remota:** Enlaces de salida a Internet gestionados por la OTI, enlaces dedicados WAN hacia centros experimentales (Camacani, Illpa) y canales de acceso remoto seguro (VPNs).

Sec 4.4 Aplicaciones y Sistemas de Información

- **Sistemas Académicos Críticos:** Plataforma de Matrícula e Intranet (`matricula.unap.edu.pe`), Plataforma de Campus Virtual Moodle (`campus.unap.edu.pe`, `aulavirtual.unap.edu.pe`) y subsistemas asociados a la Dirección General de Asuntos Académicos.
- **Sistemas de Gestión Pública y Trámite:** Sistema de Trámite Documentario SITRAD (`tramiteapp.unap.edu.pe`), Mesa de Partes Digital y Portal de Transparencia Universitaria.
- **Sistemas de Soporte y Control Institucional:** Módulos de recaudación y pagos de tesorería, portal de Admisión (`admision.unap.edu.pe`), servicios biométricos de personal (`apibiometrico.unap.edu.pe`) y repositorio DSpace (`repositorio.unap.edu.pe`).
- **Entornos de Desarrollo y Homologación:** Servidores intermedios (`dev.*`, `dev2.*`, `prue1.*`) expuestos o internos utilizados por el equipo de sistemas para el despliegue de nuevas funcionalidades.

Sec 4.5 Bases de Datos y Almacenamiento de Información

- **Motores de Bases de Datos Relacionales:** Servidores PostgreSQL, Microsoft SQL Server, MySQL y Oracle que resguardan tablas de matrículas, actas de notas, legajos de personal docente y registros de pago.
- **Repositorios de Almacenamiento Estructurado y No Estructurado:** Expedientes digitalizados, resoluciones rectorales, tesis de grado y respaldos de configuración de red.

Sec 4.6 Correo Institucional, Mensajería e Identidad Federada

Todo el dominio de correo `@unap.edu.pe` desplegado sobre plataformas de colaboración en la nube (Google Workspace / Microsoft 365), incluyendo los mecanismos de autenticación única (*Single Sign-On* - SSO), repositorios Drive compartidos y listas de distribución oficial institucional.

Sec 4.7 Servicios en la Nube y Proveedores Tecnológicos

- **Instancias en la Nube Pública:** Cargas de trabajo en AWS, Azure y Google Cloud, servicios de alojamiento externo, pasarelas de pago bancarias y certificados SSL/TLS emitidos para el dominio de la universidad.
- **Gestión de Terceros y Proveedores:** Contratos de servicios tecnológicos que estipulan acuerdos de confidencialidad (NDA), gestión controlada de accesos remotos y cláusulas de responsabilidad en ciberseguridad conforme al estándar Zero Trust.

5 INVENTARIO Y CLASIFICACIÓN DE ACTIVOS

En este capítulo se presenta el inventario exhaustivo de activos de información de la UNAP, la metodología de valoración basada en la tríada CID, los criterios de criticidad y la matriz consolidada de los 20 activos centrales de la universidad.

Sec 5.1 Metodología de Identificación y Valoración

Para la elaboración del inventario y la matriz de clasificación de activos de la Universidad Nacional del Altiplano de Puno (UNAP), se combinó el relevamiento de activos físicos del Centro de Procesamiento de Datos (Data Center OTI) y dependencias administrativas con una auditoría pasiva de la superficie de exposición externa mediante registros públicos de Transparencia de Certificados SSL/TLS (*Certificate Transparency Logs* vía `crt.sh`). Este procedimiento permitió registrar los servicios web, paneles de administración, bases de datos y nodos de red asociados a la zona DNS `unap.edu.pe`.

La valoración de cada activo se determinó evaluando el impacto que sufriría la universidad ante la pérdida o degradación de las tres dimensiones de la seguridad de la información:

- **Confidencialidad (C):** Impacto derivado de la divulgación no autorizada de datos personales de estudiantes/docentes, registros financieros o propiedad intelectual (conforme a la Ley N° 29733).
- **Integridad (I):** Impacto provocado por la alteración no autorizada de calificaciones, actas académicas, resoluciones rectorales o tablas contables.
- **Disponibilidad (D):** Impacto operativo generado por la interrupción temporal o permanente del servicio durante periodos críticos (semanas de matrícula, procesamiento de planillas o sesiones de Consejo Universitario).

Cada dimensión se califica en una escala ordinal de 1 a 4:

- **1 (Bajo):** Afectación mínima o insignificante; el daño es subsanable de forma inmediata con impacto operativo nulo.
- **2 (Medio):** Pérdida de eficiencia operativa en áreas no esenciales o exposición de datos institucionales de carácter público.
- **3 (Alto):** Afectación severa a procesos administrativos/financieros con consecuencias normativas o daño reputacional institucional significativo.
- **4 (Crítico):** Parálisis total de las actividades académicas/administrativas, alteración masiva de actas oficiales o contingencia legal directa frente a SUNEDU y entes del Estado.

Sec 5.2 Criterio de Clasificación Institucional

El nivel global de criticidad asignado al activo corresponde al valor máximo obtenido entre sus dimensiones individuales:

$$\text{Criticidad} = \max(C,\ I,\ D)$$

Este criterio garantiza que un activo con exigencia crítica en una sola dimensión (por ejemplo, integridad absoluta de notas académicas) reciba el tratamiento prioritario que le corresponde:

- **Crítico (Nivel 4):** Activos esenciales para la continuidad académica, la recaudación y la gobernanza de la UNAP. Su compromiso paraliza la institución.
- **Alto (Nivel 3):** Sistemas de trámite documentario, recaudación, recursos humanos y servicios de comunicación oficial.
- **Medio (Nivel 2):** Plataformas de divulgación científica, repositorios documentales, portales de escuelas profesionales y estaciones de trabajo administrativas.
- **Bajo (Nivel 1):** Sitios web puramente informativos, blogs de eventos y páginas estáticas sin interacción con bases de datos internas.

Sec 5.3 Matriz Consolidada de Clasificación de Activos (UNAP)

A continuación, se detalla el inventario estructurado de los 20 activos de información evaluados en el ecosistema digital de la UNAP:

ID	Nombre	Tipo	Endpoint / Ubic.	Custodio	C	I	D	Clasif.	Justificación de Criticidad
ACT-01	Base de Datos Académica	Base de Datos (PostgreSQL / Oracle)	Data Center OTI (VLAN 10)	Admin. BD / Dir. Asuntos Acad.	4	4	4	**Crítico**	Contiene el historial de notas, créditos y matrículas de más de 19,000 alumnos; daño legal irreversible.
ACT-02	Sistema de Matrícula	App Web / API (.NET Core)	`matricula.unap.edu.pe`	OTI / Unidad de Sistemas	4	4	4	**Crítico**	Proceso medular de inicio de semestre; expuesto a picos y alteración de vacantes.
ACT-03	Campus Virtual Moodle	LMS (PHP / Linux)	`campus.unap.edu.pe`	OTI / Educación Virtual	3	4	4	**Crítico**	Clases, tareas y evaluaciones en línea de pre y posgrado; paraliza la docencia si cae.
ACT-04	Enlaces WAN Switch Core	Redes y Comunicaciones	Data Center OTI Campus Central	Unidad de Redes y Telecom.	2	4	4	**Crítico**	Troncal de fibra y enrutamiento borde; su falla aísla los servidores internos.
ACT-05	Respaldo Local (NAS)	Almacenamiento Respaldo	Data Center OTI (VLAN 15)	Administrador Servidores OTI	4	4	4	**Crítico**	Última línea de defensa institucional ante ataques de ransomware catastróficos.
ACT-06	Correo y Suite Cloud	SaaS / Cloud	`@unap.edu.pe` (Google / M365)	OTI / Secretaría General	4	3	3	**Alto**	Identidad federada (SSO) y canal legal; vector principal de ataques de Spear-Phishing.
ACT-07	Trámite (SITRAD)	App Web / BD	`tramiteapp.unap.edu.pe`	Secretaría General / Trámite	3	4	3	**Alto**	Gestión de resoluciones de Consejo Universitario y decretos con valor legal vinculante.

ID	Nombre	Tipo	Endpoint / Ubic.	Custodio	C	I	D	Clasif.	Justificación de Criticidad
ACT-08	Sistema de Admisión	App Web / BD	`admision.unap.edu.pe`	Comisión Permanente Admisión / OTI	4	4	4	**Crítico**	Pagos, vacantes y resultados de exámenes; alto escrutinio público y riesgo de fraude.
ACT-09	Tesorería y Caja	Software Financiero / BD	`tesoreria.unap.edu.pe`	Dir. General Administración	4	4	3	**Alto**	Recaudación de tasas educativas, conciliaciones bancarias y transferencias del MEF.
ACT-10	Planillas y Remunerac.	Software RRHH / BD	`remuneraciones.unap.edu.pe`	Oficina de Recursos Humanos	4	4	2	**Alto**	Custodia cuentas bancarias y haberes de docentes y administrativos (Ley N° 29733).
ACT-11	Marcación Biométrica	API REST / Microservicio	`apibiometrico.unap.edu.pe`	Oficina de Personal / OTI	3	3	2	**Alto**	Datos sensibles de asistencia de trabajadores; expuesto a manipulación de horarios.
ACT-12	Firewall UTM	Dispositivo Seguridad	Borde de Red (Gateway)	Unidad de Redes y Ciberseg.	3	4	4	**Crítico**	Filtrado perimetral, inspección y VPN institucional; si cae, colapsa el perímetro.
ACT-13	Entornos Dev Expuestos	Servidores Web / Staging	`dev.unap.edu.pe`, `prue1.*`	Desarrollo OTI	3	2	1	**Alto (R.)**	Aunque su valor operativo es bajo, representa vector vulnerable de entrada a la red.
ACT-14	Paneles Hosting cPanel	Consolas Web Hosting	`cpanel.portal.*`, `webdisk.*`	Admin. Web / Facultades	4	4	2	**Alto (R.)**	Consolas de gestión expuestas a Internet con riesgo de fuerza bruta y toma de control.
ACT-15	Repositorio DSpace	Gestor Documental	`repositorio.unap.edu.pe`	Vicerrectorado Investigación	1	3	2	**Medio**	Tesis y producción científica; públicos, pero su desfiguración afecta reputación.
ACT-16	Revistas Científicas	App Web (PHP)	`revistas.unap.edu.pe`	Vicerrectorado Investigación	1	3	2	**Medio**	Publicaciones indexadas; impacto directo en la reputación académica y licenciamiento.
ACT-17	Portal Institucional	CMS Web Informativo	`www.unap.edu.pe`	Oficina Comunicaciones / OTI	1	3	3	**Medio**	Rostro digital institucional; blanco habitual de Web Defacement o saturación DoS.
ACT-18	Portales de Facultades	Sitios Informativos	`derecho.unap.edu.pe`, etc.	Coordinadores Web Fac.	1	2	1	**Bajo**	Información de mallas curriculares; sin transacciones ni autenticación crítica.
ACT-19	Estaciones Admin.	Endpoints (Windows)	Oficinas Admin. (VLAN 30)	Jefaturas / Usuarios Finales	3	3	2	**Medio**	Vector común de entrada de malware (phishing/USB); almacena documentos locales.
ACT-20	Labs Cómputo Alumnos	Endpoints Compartidos	Pabellones Fac. (VLAN 40)	Responsables Lab / Decanatos	1	2	2	**Medio**	Equipos de alta rotación con riesgo de virus; deben aislarse de la red de servidores.

Sec 5.4 Conclusiones del Inventario de Activos y Brechas Identificadas

El análisis de criticidad e interdependencia de los 20 activos de la UNAP permite formular las siguientes conclusiones estratégicas de seguridad:

- **Sobreexposición de Activos Administrativos en Internet:** Se evidencia la exposición pública de subdominios correspondientes a consolas cPanel, webdisk y endpoints de desarrollo (`dev.*`, `dev2.*`, `prue1.*`). Bajo los lineamientos de Zero Trust, ninguno de estos servicios debe ser accesible directamente desde Internet, sino que deben confinarse a subredes de gestión accesibles únicamente mediante VPN corporativa con autenticación multifactor (MFA).
- **Concentración de Criticidad en el Dominio Académico:** Los activos **ACT-01** (Base de Datos), **ACT-02** (Matrícula) y **ACT-03** (Campus Virtual) concentran la mayor valoración de riesgo (Criticidad $= 4$). Un incidente en cualquiera de ellos bloquea las operaciones académicas de la universidad, lo que fundamenta priorizar el análisis de amenazas STRIDE y la implementación de controles en este segmento.
- **Dependencia de la Identidad Federada:** El correo institucional (**ACT-06**) actúa como la llave maestra de acceso a múltiples servicios. La ausencia de DMARC detectada en el dominio `unap.edu.pe` expone este activo a suplantaciones directas (*Spoofing*), amenazando la integridad del resto del inventario institucional.

6 ANÁLISIS DE AMENAZAS MEDIANTE STRIDE

En este capítulo se formaliza la descomposición funcional y el modelado preventivo de amenazas bajo el marco STRIDE sobre el sistema más crítico de la UNAP: la plataforma transaccional de matrícula académica.

Sec 6.1 Metodología de Modelado STRIDE

La metodología STRIDE (desarrollada originalmente por Praerit Garg y Loren Kohnfelder en Microsoft) se fundamenta en la descomposición funcional de un sistema para responder de forma sistemática a cuatro interrogantes operativas:

1. **¿En qué estamos trabajando?** Construcción del Diagrama de Flujo de Datos (DFD).
2. **¿Qué puede salir mal?** Mapeo de categorías STRIDE sobre los elementos y límites de confianza.
3. **¿Qué vamos a hacer al respecto?** Definición de controles preventivos y correctivos.
4. **¿Hicimos un buen trabajo?** Evaluación residual del riesgo y verificación de controles.

El análisis modela las seis categorías de amenazas frente a las propiedades clásicas de seguridad de la información:

Categoría STRIDE	Propiedad Violada	Definición en el Contexto del Software
S — Spoofing	**Autenticación**	Un actor malicioso finge ser un usuario legítimo (estudiante/docente) o suplanta un servicio del sistema.
T — Tampering	**Integridad**	Modificación malintencionada y no autorizada de datos en tránsito, en memoria o en reposo.
R — Repudiation	**No Repudio**	Un usuario realiza una acción transaccional y el sistema carece de evidencia inmutable para adjudicarle la autoría.
I — Info Disclosure	**Confidencialidad**	Exposición de credenciales, tokens, datos personales o metadatos de arquitectura a entidades no autorizadas.
D — Denial of Service	**Disponibilidad**	Saturación o degradación intencional de recursos (red, CPU, memoria, hilos web) para impedir el servicio legítimo.
E — Elevation of Priv.	**Autorización**	Un usuario con permisos limitados elude controles para ejecutar funciones de mayor privilegio administrativo.

Sec 6.2 Selección y Alcance del Sistema Objetivo

- **Sistema Evaluado:** Portal y API Transaccional de Matrícula (`https://matricula.unap.edu.pe`).
- **Capa de Borde:** Proxy inverso web `nginx/1.16.1` (Linux) encargado de la terminación TLS y enrutamiento perimetral.
- **Capa de Aplicación:** Servicio web compilado en ASP.NET Core (C#) ejecutándose sobre Kestrel/Linux, identificado mediante las cookies de sesión `.AspNetCore.Cookies` (fragmentadas en chunks) y el proveedor de estado temporal `.AspNetCore.Mvc.CookieTempDataProvider`.
- **Capa de Persistencia:** Motor de Base de Datos Académica Central (PostgreSQL / Oracle) alojado en el segmento privado del Data Center OTI.
- **Usuarios del Sistema:** Estudiantes de pregrado/posgrado (≈20,000 usuarios recurrentes), docentes y administradores de la Oficina de Tecnologías de la Información.

Sec 6.3 Diagrama de Flujo de Datos (DFD) y Límites de Confianza

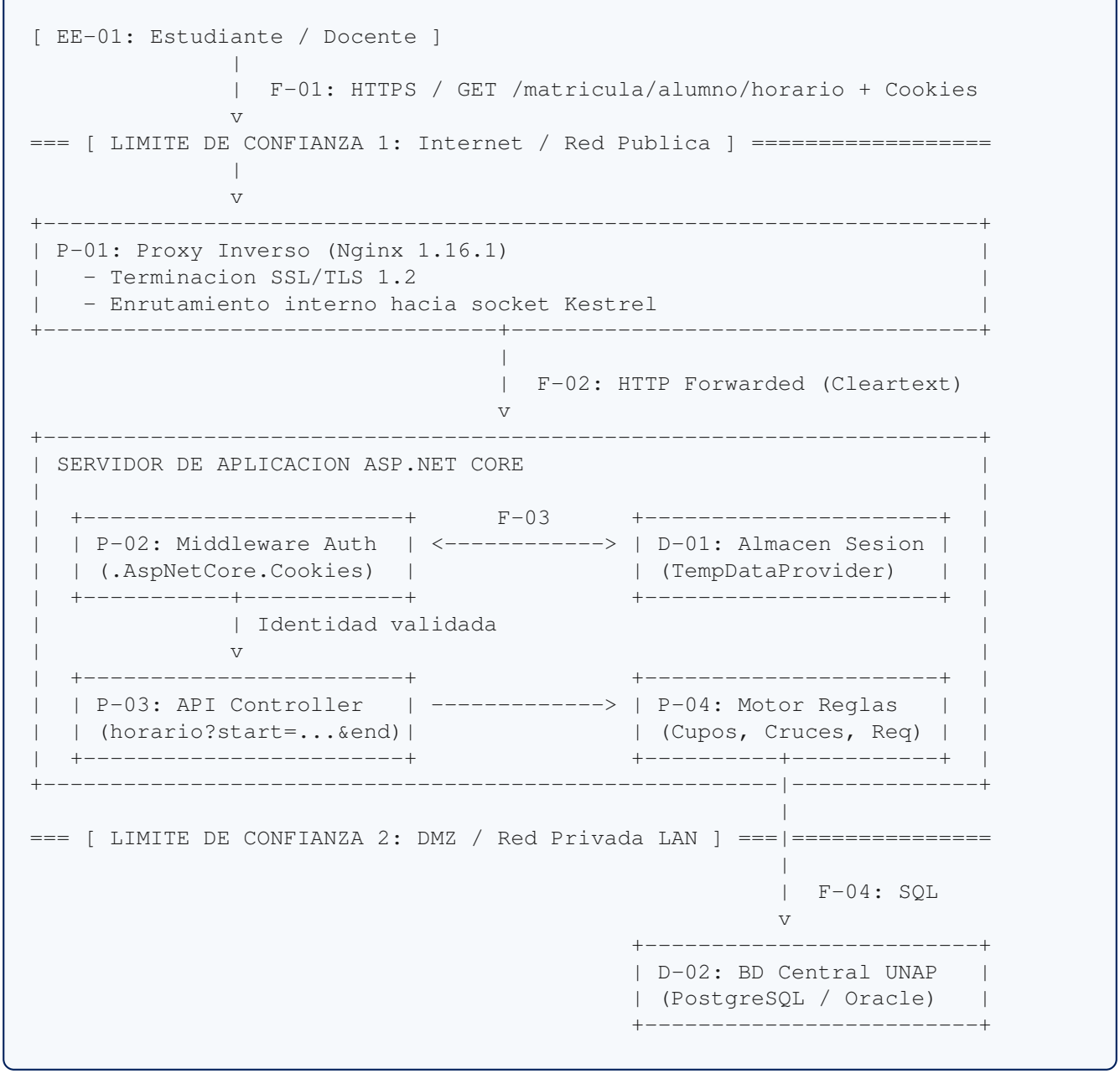
El modelado STRIDE exige delimitar claramente las fronteras de confianza (*Trust Boundaries*), que representan transiciones lógicas o físicas donde los privilegios cambian y el nivel de control disminuye.

6.3.1 Elementos del DFD Nivel 1

- **Entidades Externas (EE):** `EE-01`: Estudiante / Docente (Navegador Web / Cliente HTTP).
- **Procesos (P):**
  - `P-01`: Recepción, Terminación TLS y Reverse Proxy (Nginx 1.16.1).
  - `P-02`: Gestión de Sesión y Autenticación (Middleware ASP.NET Core Identity).
  - `P-03`: Consulta y Despliegue de Horario/Oferta (Endpoint `/matricula/alumno/horario`).
  - `P-04`: Lógica de Inscripción y Validación de Reglas (Cálculo de créditos, prerrequisitos y vacantes).
- **Almacenes de Datos (D):**
  - `D-01`: Almacén de Estado Temporal / Sesiones en Memoria (`CookieTempDataProvider`).
  - `D-02`: Base de Datos Académica Central (Tablas: Alumnos, Cursos, Actas, Cupos).
- **Flujos de Datos (F):**
  - `F-01`: Petición inicial HTTPS / Envío de credenciales o cookies (Cliente → Nginx).
  - `F-02`: Petición interna HTTP proxy-pass / Encabezados `X-Forwarded-*` (Nginx → ASP.NET Core).
  - `F-03`: Lectura/Escritura de estado de sesión (ASP.NET Core ↔ D-01).
  - `F-04`: Consultas transaccionales SQL / Stored Procedures (ASP.NET Core ↔ D-02).
  - `F-05`: Retorno de payload JSON con horario y estado HTTP 200 (ASP.NET Core → Nginx → Cliente).

6.3.2 Esquema Arquitectónico del DFD Nivel 1

>_ | Arquitectura DFD Nivel 1 y Límites de Confianza (matricula.unap.edu.pe)



Sec 6.4 Evaluación de Riesgos (Criterio DREAD Adaptado)

Para cuantificar objetivamente la severidad de las amenazas identificadas en el sistema de matrícula, se aplica el modelo DREAD de Microsoft, evaluando cinco dimensiones con puntajes del 1 al 10:

$$\text{Riesgo Global} = \frac{\text{Damage} + \text{Reproducibility} + \text{Exploitability} + \text{Affected Users} + \text{Discoverability}}{5}$$

- **Damage (Daño potencial):** Perjuicio si el ataque tiene éxito (1 = Mínimo; 10 = Secuestro total de datos o parálisis institucional).
- **Reproducibility (Reproducibilidad):** Facilidad de replicar el ataque una vez descubierto (1 = Muy difícil o circunstancial; 10 = Funciona el 100 % de las veces).
- **Exploitability (Facilidad de explotación):** Destreza y herramientas requeridas (1 = Habilidades avanzadas de kernel/0-day; 10 = Petición HTTP simple con script público).
- **Affected Users (Usuarios afectados):** Proporción de la universidad impactada (1 = Un usuario individual; 10 = Toda la comunidad universitaria).
- **Discoverability (Descubribilidad):** Facilidad para hallar la debilidad (1 = Requiere código fuente; 10 = Visible en cabeceras HTTP públicas).

Escala de Severidad Cualitativa: Bajo: $1{,}0 - 4{,}9$ | **Medio:** $5{,}0 - 6{,}9$ | **Alto:** $7{,}0 - 8{,}9$ | **Crítico:** $9{,}0 - 10{,}0$.

Sec 6.5 Matriz de Análisis STRIDE del Sistema de Matrícula (UNAP)

La siguiente matriz documenta las amenazas concretas detectadas a partir de las vulnerabilidades verificadas en el relevamiento perimetral:

Cat.	Amenaza Identificada	Comp.	Vulnerabilidad Base	DREAD / Nivel	Controles de Mitigación Propuestos
S	Suplantación de Sesión: Robo de cookies `.AspNetCore.Cookies` e impersonación de identidad del alumno.	F-01, EE-01, P-02	Sin binding de sesión a IP/huella TLS; sin revocación forzada tras logout.	**7.4** Alto (8,7,6,9,7)	1. Revocación de tokens JWT / claims en Redis. 2. MFA obligatorio para docentes y condicional alumnos. 3. Binding de cookie a huella criptográfica de conexión.
T	Manipulación en Tránsito (SSL Stripping): Interceptación en texto plano de parámetros y cookies en Wi-Fi.	F-01, Límite 1	Ausencia de HSTS (`Strict-Transport-Security`) en cabeceras web.	**8.0** Alto (8,8,7,8,9)	1. Inyectar directiva HSTS estricta en Nginx (`max-age=31536000; preload`). 2. Redirección HTTP → HTTPS forzada (código 301).
T	Manipulación de Horario y Cruces: Peticiones alteradas en `horario?start` para forzar cupos colapsados.	P-03, P-04, F-04	Validación de reglas en cliente sin doble chequeo atómico en backend.	**7.4** Alto (7,9,8,6,7)	1. Validación transaccional atómica en backend y base de datos (nivel Serializable). 2. Verificación criptográfica de parámetros cliente.
R	Repudio de Matrícula: Estudiante alega que el sistema no registró su matrícula o notas sin refutación técnica.	P-02, D-02, F-04	Logs web volátiles; solo registran código 200 sin User-ID ni hash transaccional.	**5.8** Medio (6,6,5,7,5)	1. Bitácora transaccional inmutable (WORM) con User-ID, IP, timestamp NTP y hash del evento. 2. Envío centralizado a servidor Syslog / SIEM externo.

Cat.	Amenaza Identificada	Comp.	Vulnerabilidad Base	DREAD / Nivel	Controles de Mitigación Propuestos
I	Fuga de Versiones Obsoletas: Atacantes obtienen tecnología exacta para descargar exploits públicos.	P-01, Límite 1	Cabecera expuesta: `Server: nginx/1.16.1` (versión 2019 con CVEs acumulados).	**8.8** Alto (7,10,8,9,10)	1. Ocultar firma con `server_tokens off;` en Nginx. 2. Actualizar binario de Nginx a rama estable 1.26+. 3. Desplegar reglas de inspección perimetral WAF.
I	Fuga de Sesión Temporal: Interceptación de cookie `.AspNetCore.Mvc.CookieTempDataProvider`.	D-01, F-01	Cookie temporal no incluye atributo `Secure` en directiva `Set-Cookie`.	**7.0** Alto (6,7,6,8,8)	1. Endurecer política de cookies en `Program.cs`: `SecurePolicy = CookieSecurePolicy.Always; SameSite = SameSiteMode.Strict;`.
D	DoS por Agotamiento de Hilos: Colapso de proxy Nginx o cola Kestrel por concurrencia masiva en apertura.	P-01, P-03, D-02	Sin limitación de tasa (*Rate Limiting*) por IP ni arquitectura elástica.	**9.0** Crítico (9,9,8,10,9)	1. Configurar rate limiting en Nginx (`limit_req_zone`). 2. Balanceador de carga con instancias API redundantes. 3. Implementar sala de espera virtual (*Waiting Room*).
E	Elevación de Privilegios (IDOR): Modificación de IDs de usuario en URL para acceder a rutas de docentes.	P-03, P-04, F-04	Control de acceso basado en URL sin verificación de claims de rol en backend.	**7.4** Alto (9,7,7,8,6)	1. Autorización basada en políticas de claims (`[Authorize(Roles = "Docente,Admin")]`). 2. Validación de pertenencia obligatoria entre sesión y recurso.

Sec 6.6 Procedimiento de Implementación de Controles Mitigadores

Para transformar los hallazgos de la matriz STRIDE en salvaguardas operativas inmediatas dentro de la infraestructura de la UNAP, se establecen tres niveles de acción técnica:

6.6.1 A. Hardening Inmediato en Servidor Web Nginx (P-01)

Se debe modificar el bloque de configuración perimetral en el archivo institucional `/etc/nginx/sites-available/matricula.unap.edu.pe`:

>_ | Configuración Nginx de Mitigación STRIDE – matricula.unap.edu.pe

```
# Mitigacion STRIDE: Information Disclosure (Ocultamiento de version)
server_tokens off;

# Mitigacion STRIDE: Tampering y Spoofing (HSTS y proteccion de cabeceras)
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains;
   preload" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;

# Mitigacion STRIDE: Denial of Service (Proteccion contra rafagas DoS)
limit_req_zone $binary_remote_addr zone=api_matricula:20m rate=15r/s;

server {
    listen 443 ssl http2;
    server_name matricula.unap.edu.pe;

    location / {
        limit_req zone=api_matricula burst=25 nodelay;
        proxy_pass http://127.0.0.1:5000; # Backend Kestrel ASP.NET Core
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}
```

6.6.2 B. Aseguramiento del Manejo de Sesiones en ASP.NET Core (P-02 / D-01)

En el archivo de inicialización del backend (`Program.cs`), forzar el endurecimiento de las cookies transaccionales:

>_ | Endurecimiento de Cookies y Autenticación en Program.cs

```
builder.Services.Configure<CookiePolicyOptions>(options =>
{
    // Mitigacion STRIDE: Information Disclosure y Tampering en Cookies
    options.HttpOnly = Microsoft.AspNetCore.CookiePolicy.HttpOnlyPolicy.Always;
    options.Secure = Microsoft.AspNetCore.Http.CookieSecurePolicy.Always;
    options.MinimumSameSitePolicy = Microsoft.AspNetCore.Http.SameSiteMode.
   Strict;
});

builder.Services.AddAuthentication(CookieAuthenticationDefaults.
   AuthenticationScheme)
    .AddCookie(options =>
    {
        options.Cookie.Name = "__Host-UNAP-Auth"; // Cookie de prefijo seguro
        options.ExpireTimeSpan = TimeSpan.FromMinutes(20);
        options.SlidingExpiration = true;
    });
```

6.6.3 C. Control Transaccional en Base de Datos (P-04 / D-02)

Para mitigar la manipulación de prerrequisitos y vacantes (*Tampering* y *Elevation of Privilege*), toda inscripción debe ejecutarse dentro de un procedimiento almacenado transaccional que valide atómicamente el cupo con bloqueo pesimista:

>_ | Función SQL Transaccional con Bloqueo FOR UPDATE contra Race Conditions

```
-- Mitigacion STRIDE: Tampering (Bloqueo pesimista contra condiciones de
   carrera)
CREATE OR REPLACE FUNCTION sp_inscribir_asignatura(
    p_alumno_id INT,
    p_curso_id INT,
    p_grupo_id INT
) RETURNS BOOLEAN AS $$
DECLARE
    v_vacantes INT;
    v_inscritos INT;
BEGIN
    SELECT vacantes_totales INTO v_vacantes
    FROM oferta_academica
    WHERE grupo_id = p_grupo_id FOR UPDATE;

    SELECT COUNT(*) INTO v_inscritos
    FROM matricula_detalle
    WHERE grupo_id = p_grupo_id;

    IF v_inscritos < v_vacantes THEN
        INSERT INTO matricula_detalle(alumno_id, curso_id, grupo_id,
   fecha_registro)
        VALUES (p_alumno_id, p_curso_id, p_grupo_id, NOW());
        RETURN TRUE;
    ELSE
        RAISE EXCEPTION 'Cupo colapsado: no hay vacantes disponibles';
        RETURN FALSE;
    END IF;
END;
$$ LANGUAGE plpgsql;
```

7 INTELIGENCIA DE AMENAZAS (THREAT INTELLIGENCE)

En este capítulo se formaliza el programa de vigilancia activa, detección temprana y análisis continuo de ciberamenazas (Cyber Threat Intelligence - CTI), orientado a anticipar y neutralizar vectores de ataque contra el ecosistema tecnológico de la Universidad Nacional del Altiplano de Puno.

Sec 7.1 Fundamentación y Objetivos de la Vigilancia Institucional

La Inteligencia de Amenazas (*Cyber Threat Intelligence* — CTI) en la Universidad Nacional del Altiplano de Puno no se concibe como una simple acumulación de listas de bloqueo, sino como un proceso analítico continuo destinado a transformar datos contextuales de adversarios en decisiones defensivas proactivas.

El propósito medular de CTI en la UNAP es anticipar los vectores de intrusión antes de que alcancen la fase de ejecución, mitigando los riesgos identificados en el relevamiento perimetral:

- **Suplantación de Identidad y Typosquatting:** Explotación de la reputación institucional para el despliegue de portales fraudulentos que clonan la interfaz de inicio de sesión de matrícula y campus virtual.
- **Explotación del Vector de Mensajería:** Aprovechamiento sistemático de la ausencia de registros DMARC (`NXDOMAIN`) y directivas permisivas SPF (`~all`) en el dominio `unap.edu.pe` para el envío de campañas de *Spear-Phishing* dirigidas contra autoridades, decanatos y docentes.
- **Ataques a Software Expuesto:** Campañas masivas de explotación orientadas a versiones legadas de servidores web (como la rama `nginx/1.16.1` detectada) y vulnerabilidades en gestores de contenido web institucionales.
- **Fuga de Credenciales:** Detección de cuentas `@unap.edu.pe` expuestas en filtraciones masivas (*stealer logs* o *data dumps* en la Dark Web).

Sec 7.2 Ciclo Operativo de Threat Intelligence en la UNAP

El flujo operativo se modela a través de un ciclo continuo de seis fases adaptado al ámbito universitario:



Figura 7.1: Ciclo Continuo de Threat Intelligence adaptado a la UNAP.

- **Dirección y Planeación:** El Oficial de Seguridad (CISO) y la Jefatura de OTI definen las prioridades de vigilancia de acuerdo con el calendario académico (épocas críticas: convocatorias de admisión, matrículas semestrales, elecciones y subida de actas de notas).
- **Recolección de Información:** Ingesta de fuentes especializadas y telemetría institucional:
  - *Fuentes Abiertas y Plataformas CTI (OSINT):* AlienVault OTX, AbuseIPDB, VirusTotal, Shodan, crt.sh (monitoreo de nuevos certificados emitidos para `*.unap.edu.pe`).
  - *Fuentes Estatales y Sectoriales:* Alertas del Centro Nacional de Seguridad Digital (CSIRT Nacional de la PCM/SGTD) y RENATA/RedCLARA para redes académicas.
  - *Telemetría Interna:* Logs de accesos HTTP de Nginx, registros de autenticación de Google Workspace / M365 y eventos del firewall perimetral.
- **Procesamiento y Normalización:** Extracción y depuración de Indicadores de Compromiso (IoCs) categorizados bajo el estándar estructurado STIX/TAXII (direcciones IP, dominios apócrifos, hashes SHA-256 de ejecutables/documentos maliciosos y patrones URI).
- **Análisis y Correlación:** Cruce de los IoCs extraídos contra las bases de datos de accesos de la UNAP. Si una IP maliciosa con reporte internacional de fuerza bruta ha consultado el endpoint `/matricula/alumno/horario`, se califica como incidente potencial en curso.
- **Difusión:** Emisión de boletines técnicos dirigidos al equipo de infraestructura para el bloqueo inmediato, y comunicados preventivos hacia la comunidad universitaria si el vector apunta a ingeniería social.
- **Retroalimentación y Acción Defensiva:** Inyección automática/manual de reglas en el Firewall UTM (bloqueo de IPs), en el servidor proxy Nginx (denegación de User-Agents maliciosos) y en la pasarela de correo electrónico.

Sec 7.3 Taxonomía de Indicadores de Compromiso (Pirámide del Dolor)

Para enfocar los esfuerzos del equipo de seguridad donde generen mayor impacto defensivo, la UNAP clasifica los hallazgos de Threat Intelligence según la Pirámide del Dolor de David Bianco:

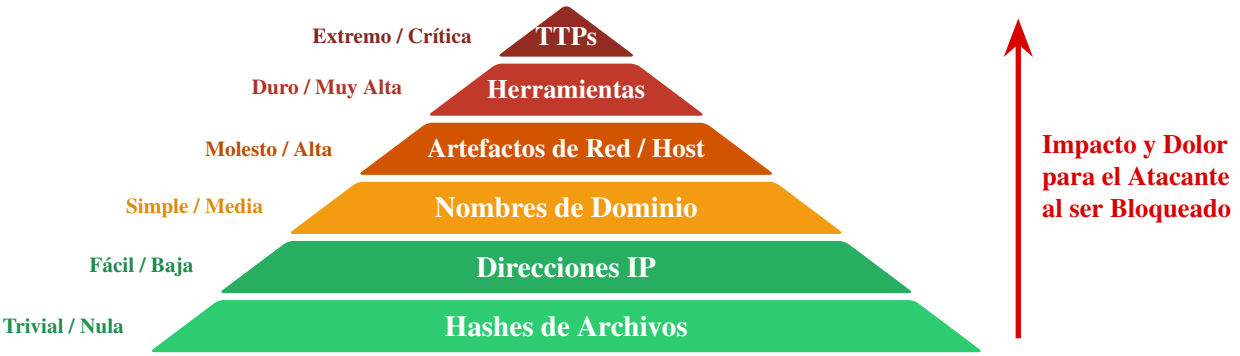


Figura 7.2: Pirámide del Dolor de David Bianco aplicada a la clasificación de IoCs en la UNAP.

Nivel	Tipo de Indicador	Dificultad Atacante	Aplicación Defensiva en la UNAP
Trivial	Hashes de archivos (MD5, SHA-256)	Nula (cambia 1 bit y el hash varía).	Bloqueo en estaciones de trabajo y laboratorios vía EDR/Antivirus institucional.
Fácil	Direcciones IP	Baja (el atacante rota proxies y VPNs).	Listas negras dinámicas en el Firewall perimetral y WAF de la universidad.
Simple	Nombres de Dominio	Media (requiere comprar y registrar otro).	Bloqueo a nivel de servidores DNS locales (DNS Sinkhole) y monitoreo WHOIS/crt.sh.
Molesto	Artefactos de Red / Host	Alta (requiere reescribir herramientas).	Detección de patrones específicos en cabeceras HTTP o nombres de tareas programadas.
Duro	Herramientas	Muy Alta (debe reprogramar o buscar nuevo software).	Reglas YARA y firmas de comportamiento contra herramientas automatizadas (Hydra, Sqlmap).
Extremo	TTPs (Tácticas, Técnicas y Procedimientos)	Crítica (obliga al atacante a cambiar su modo de operar).	Mapeo MITRE ATT&CK: Mitigar spearphishing exigiendo MFA obligatorio e implementando HSTS.

Sec 7.4 Producto Operativo: Boletín de Inteligencia de Amenazas

A continuación se presenta el modelo oficial de boletín técnico generado para documentar una amenaza real y activa detectada durante el relevamiento de la superficie institucional:

>_ | Boletín Oficial de Inteligencia de Amenazas - CSIRT-UNAP / OTI

```
==========================================================================
       OFICINA DE TECNOLOGIAS DE LA INFORMACION - UNAP
            UNIDAD DE REDES Y CIBERSEGURIDAD (SOC-UNAP)
==========================================================================
BOLETIN DE INTELIGENCIA DE AMENAZAS | REF: CTI-UNAP-2026-003
FECHA DE EMISION: 17 de Octubre de 2026
NIVEL DE SEVERIDAD: ALTO (AMBAR)
TLP: AMBER (Uso exclusivo interno OTI / Administradores de Red y Sistemas)
==========================================================================

1. TITULO:
Campana de Spear-Phishing y Explotacion Perimetral orientada a
credenciales academicas aprovechando ausencia de directiva DMARC.

2. RESUMEN EJECUTIVO:
El equipo de seguridad ha detectado el registro y circulacion de
vectores de suplantacion dirigidos a la comunidad universitaria de la
UNAP. La amenaza combina el envio de correos fraudulentos con remitente
falseado (@unap.edu.pe) -posibilitado por la inexistencia de registros
DMARC en la zona DNS institucional- con portales de phishing que clonan
el inicio de sesion de matricula, buscando capturar credenciales de
acceso (.AspNetCore.Cookies) y datos personales.

3. ANALISIS DE LA AMENAZA Y VECTORES TECNICOS:
A. Vector de Entrega (Email Spoofing):
   - Aprovechamiento del registro SPF actual: "v=spf1 ... ~all" (SoftFail).
   - Ausencia total del host "_dmarc.unap.edu.pe" (NXDOMAIN verificado).
   - Servidores de correo externos entregan los mensajes a las bandejas
     de docentes y alumnos al no existir directivas de rechazo (p=reject).

B. Vector de Explotacion Web (Infraestructura Clonada):
   - Despliegue de un dominio apocrifo: "matricula-unap-edu[.]pe".
   - Certificado SSL gratuito emitido para dar apariencia de legitimidad.
   - Formulario que captura usuario y contrasena, y retransmite al
     backend legitimo para evitar sospechas inmediatas del usuario.

4. INDICADORES DE COMPROMISO (IoCs):
   A. Indicadores de Red (Dominios y URLs Maliciosas):
      - Dominio: matricula-unap-edu[.]pe
      - Dominio: unap-soporte-academico[.]com
      - URL Phishing: hxxps://matricula-unap-edu[.]pe/login/alumno
      - URL Payload:  hxxps://unap-soporte-academico[.]com/assets/auth_sync.js

   B. Direcciones IP de Servidores C2 / Phishing:
      - 185.220.101.45 (Trafico scanning hacia /matricula/alumno/*)
      - 194.26.29.112  (Servidor hosting del portal falso)
      - 45.154.255.89  (Nodo Tor con fuerza bruta sobre Nginx 1.16.1)
```

```
   C. Hashes Criptograficos de Adjuntos Simulados (SHA-256):
      - 8f4b1e5a2c3d0b9a8f7e6d5c4b3a2f1e0d9c8b7a6f5e4d3c2b1a0f9e8d7c6b5a
        (Falso archivo: "Cronograma_Rectificacion_Matricula_2026.pdf.exe")

   D. Asuntos de Correo Utilizados en la Campana:
      - "[URGENTE] Regularizacion obligatoria de matricula 2026"
      - "Actualizacion de seguridad requerida en su cuenta UNAP"

5. MAPEO CON METODOLOGIAS Y MARCOS DE SEGURIDAD:
   - STRIDE: Spoofing (S), Tampering (T), Information Disclosure (I).
   - MITRE ATT&CK:
     * T1566.002 (Phishing: Spearphishing Link)
     * T1589.002 (Gather Victim Identity Info: Email Addresses)
     * T1078.003 (Valid Accounts: Local Accounts)
   - Cyber Kill Chain:
     * Fase 1 (Reconocimiento) -> Fase 3 (Entrega) -> Fase 4 (Explotacion).
6. ACCIONES DEFENSIVAS INMEDIATAS APLICADAS:
   [X] Bloqueo de direcciones IP atacantes en Firewall FortiGate.
   [X] Inyeccion en servidores DNS resolver para redirigir dominios
       maliciosos a IP de Loopback (127.0.0.1 - Sinkhole).
   [X] Regla de cuarentena estricta en panel de correo para mensajes
       cuyo encabezado contenga "matricula-unap".
7. MEDIDAS ESTRUCTURALES MANDATORIAS (PROPUESTA ZERO TRUST):
   1. Gestion de DNS Institucional:
      Publicar inmediatamente el registro TXT en "_dmarc.unap.edu.pe":
      "v=DMARC1; p=quarantine; sp=quarantine; rua=mailto:seguridad@unap.edu.pe;
    pct=100"
      para forzar a los servidores receptores a enviar a cuarentena.
   2. Modificacion de SPF:
      Cambiar la directiva final de "~all" (SoftFail) a "-all" (HardFail).
   3. Despliegue de MFA:
      Exigir autenticacion multifactor (MFA) en todas las cuentas docentes
      y administrativas para neutralizar credenciales robadas.
================================================================================
```

Sec 7.5 Procedimiento de Actualización y Gobernanza

Para garantizar la sostenibilidad y eficacia operativa de la inteligencia de amenazas en la UNAP, se establecen los siguientes lineamientos de gobernanza:

- **Frecuencia de Emisión:** El SOC-UNAP emitirá boletines de inteligencia bajo demanda (ante incidentes críticos de severidad Alta/Crítica) y un reporte de resumen quincenal con métricas de IoCs mitigados.
- **Repositorio Central de Indicadores:** Los IoCs se consolidarán en una plataforma de gestión de amenazas de código abierto (como MISP — *Malware Information Sharing Platform*) alojada localmente en la DMZ de la OTI, permitiendo la sincronización de listas con el firewall perimetral y el SIEM Wazuh.
- **Canal de Notificación a la Comunidad:** Ante campañas activas de ingeniería social, se emitirá una versión desclasificada y simplificada en formato infográfico a través de los canales institucionales oficiales (`prensa.unap.edu.pe`, redes sociales y banner informativo en el portal de matrícula).



Para caracterizar el comportamiento táctico de los adversarios, se utiliza la matriz **MITRE ATT&CK for Enterprise**, permitiendo identificar brechas de visibilidad e implementar reglas de detección precisas.

Sec 8.1 Estudio de TTPs Aplicables a la Superficie de la UNAP

A continuación, se describen las Tácticas, Técnicas y Procedimientos (TTPs) más relevantes para la infraestructura evaluada:

- **Reconocimiento (TA0043):**
  - **T1596 (Search Open Technical Databases):** Identificación de subdominios y certificados mediante plataformas públicas como `crt.sh`.
  - **T1589 (Gather Victim Identity Info):** Recolección de correos institucionales de autoridades y docentes desde la web institucional.
- **Acceso Inicial (TA0001):**
  - **T1566.002 (Spearphishing Link):** Envío de enlaces maliciosos simulando comunicaciones del rectorado o la OTI.
  - **T1078 (Valid Accounts):** Acceso a plataformas universitarias utilizando credenciales legítimas comprometidas sin factor MFA.
- **Ejecución (TA0002):**
  - **T1059 (Command and Scripting Interpreter):** Ejecución no autorizada de comandos en el intérprete del servidor web a través de vulnerabilidades de aplicación.
- **Persistencia (TA0003):**
  - **T1505.003 (Web Shell):** Carga de archivos maliciosos en directorios de carga (*uploads*) del Campus Virtual o portales web.
- **Escalada de Privilegios (TA0004):**
  - **T1068 (Exploitation for Privilege Escalation):** Aprovechamiento de fallos en versiones desactualizadas de software base (ej. servidores web Nginx o kernels Linux).
- **Descubrimiento (TA0007):**
  - **T1046 (Network Service Discovery):** Escaneo de puertos y servicios internos lanzado desde estaciones de cómputo o laboratorios de alumnos.

- **Movimiento Lateral (TA0008):**
  - **T1021.002 (SMB Shares):** Propagación entre estaciones de trabajo administrativas mediante carpetas compartidas sin segmentar.
- **Exfiltración (TA0010):**
  - **T1048 (Exfiltration Over Alternative Protocol):** Salida de bases de datos o información confidencial mediante canales web cifrados o protocolos no supervisados.

Sec 8.2 Matriz MITRE ATT&CK Institucional y Brechas de Visibilidad

Táctica MITRE	Técnica / ID	Escenario en la UNAP	Control / Brecha de Visibilidad
Reconocimiento	T1596 / T1589	Rastreo pasivo en crt.sh y directorio docente	Brecha: Información expuesta públicamente
Acceso Inicial	T1566.002 / T1078	Phishing con enlaces apócrifos y cuentas sin MFA	Control: Despliegue de MFA y filtrado de correo
Ejecución	T1059	Ejecución de scripts en servidores web vulnerables	Control: Restricción de permisos y WAF
Persistencia	T1505.003	Carga de Web Shell en formularios sin sanitizar	Brecha: Carencia de monitoreo de integridad FIM
Escalada Priv.	T1068	Exploits en Nginx 1.16.1 o Linux desactualizados	Control: Gestión y parcheo de vulnerabilidades
Descubrimiento	T1046	Escaneo de red interna desde laboratorios estudiantiles	Brecha: Falta de microsegmentación entre VLANs
Mov. Lateral	T1021.002	Movimiento vía SMB en redes de oficinas	Control: Deshabilitar SMBv1 y aislar puestos
Exfiltración	T1048	Extracción de tablas de notas vía HTTPS no filtrado	Control: Inspección TLS y DLP perimetral

Sec 8.3 Regla de Detección SIEM (Wazuh / Sysmon)

Para mitigar la técnica de ejecución y persistencia (T1505.003 - Web Shell), se define la siguiente regla de correlación:

>_ | Regla Wazuh para Detección de Creación de Web Shell (/etc/rules/local_rules.xml)

```
<group name='web,attack,'>
  <rule id='100250' level='12'>
    <if_group>syscheck</if_group>
    <match>/var/www/html/uploads/</match>
    <description>Alerta Critica: Creacion de archivo ejecutable (.php) en
   carpeta uploads</description>
    <mitre>
      <id>T1505.003</id>
    </mitre>
  </rule>
</group>
```

ANÁLISIS MEDIANTE CYBER KILL CHAIN

En este capítulo se modela el ciclo de intrusión lineal que un adversario ejecutaría contra el sistema académico y personal de la UNAP, determinando los puntos de interrupción defensiva.

Sec 9.1 Modelado del Ciclo Lineal de Intrusión

El escenario reconstruye un vector de intrusión dirigido hacia el personal docente y la plataforma académica:

1. **Reconocimiento (Reconnaissance):** Mapeo pasivo de subdominios universitarios (`matricula.unap.edu.pe`) y extracción de nombres y correos de directores de escuela y docentes mediante fuentes abiertas (OSINT).
2. **Armamento (Weaponization):** Clonación visual fidedigna del formulario de inicio de sesión de `matricula.unap.edu.pe` montado en un servidor externo bajo dominio tipográfico.
3. **Entrega (Delivery):** Envío masivo de correos electrónicos fraudulentos suplantando al Vicerrectorado Académico, aprovechando la **ausencia de registro DMARC (NXDOMAIN)** y un registro **SPF excesivamente permisivo** (`~all` SoftFail) en el dominio institucional `unap.edu.pe`.
4. **Explotación (Exploitation):** El docente o alumno hace clic en el enlace malicioso e introduce sus credenciales oficiales en la página clonada apócrifa.
5. **Instalación (Installation):** El atacante captura las credenciales válidas y accede directamente a las plataformas institucionales internas sin requerimiento de segundo factor (MFA).
6. **Comando y Control (C2):** Establecimiento de túneles y sesiones interactivas cifradas HTTPS hacia el exterior que pasan desapercibidas por carecer de inspección TLS profunda.
7. **Acción sobre el Objetivo (Actions on Objectives):** Alteración de calificaciones en actas, reserva irregular de vacantes o exfiltración de tablas con información personal sensible.

Sec 9.2 Puntos de Quiebre Defensivo y Controles de Interrupción

El principio fundamental de la Cyber Kill Chain establece que neutralizar cualquier fase interrumpe la consumación del ataque:

Fase Kill Chain	Acción del Adversario en UNAP	Control Preventivo / Detectivo de Ruptura
1. Reconocimiento	Rastreo de subdominios y correos	Vigilancia OSINT, reducción de huella digital y monitoreo DNS
2. Armamento	Montaje de web clonada de matrícula	Detección temprana de typosquatting vía Threat Intelligence
3. Entrega	Envío de correo apócrifo de la UNAP	Publicación de registro DMARC estricto (`p=reject`) y SPF con `-all`
4. Explotación	Clic en enlace apócrifo de correo	Filtrado web en endpoints y concientización antispam en usuarios
5. Instalación	Inicio de sesión con credencial robada	Autenticación Multifactor obligatoria (MFA/TOTP) que bloquea el acceso
6. C2	Túnel HTTPS saliente no filtrado	Inspección profunda SSL/TLS en firewall NGFW y bloqueo de IPs C2
7. Objetivos	Extracción y alteración de notas	Control RBAC estricto, inmutabilidad de actas y alertas SIEM

>_ | Evidencia Técnica DNS: Ausencia de DMARC y SPF Permisivo

```
# Consulta de registro DMARC en el dominio institucional
$ dig _dmarc.unap.edu.pe TXT +short
;; Got SERVFAIL or NXDOMAIN (Registro DMARC inexistente)

# Consulta de registro SPF en unap.edu.pe
$ dig unap.edu.pe TXT +short
'v=spf1 ip4:161.132.24.0/24 include:_spf.google.com ~all'
# Diagnostico: El modificador ~all (SoftFail) permite suplantacion sin rechazo
    forzado
```

PLEMENTACIÓN DE ARQUITECTURA ZERO TRUST

En este capítulo se establece la estrategia de transición hacia un modelo Zero Trust, fundamentado en la premisa rectora:

> *"Nunca confiar automáticamente; verificar siempre de forma explícita y asumir la brecha".*

Sec 10.1 Pilares de la Arquitectura Zero Trust en la UNAP

La implementación abarca los cinco pilares esenciales de seguridad:

1. **Pilar Identidad:** Despliegue mandatorio de Autenticación Multifactor (MFA mediante TOTP o llaves FIDO2) para el 100 % de docentes y personal administrativo. Política rigurosa de depuración y eliminación de cuentas inactivas o egresadas.
2. **Pilar Dispositivos:** Verificación previa del estado de salud y cumplimiento del endpoint (*Device Compliance*) antes de permitir la conexión a servicios centrales o bases de datos de la universidad.
3. **Pilar Red (Microsegmentación):** Aislamiento estricto del tráfico de red a nivel de capa 3 mediante VLANs dedicadas con reglas de filtrado en Switch Core y Firewall:
   - VLAN 10: Servidores de Producción y Data Center (restringida).
   - VLAN 20: Personal Administrativo y Tesorería.
   - VLAN 30: Salas de Profesores y Docentes.
   - VLAN 40: Laboratorios de Cómputo para Estudiantes.
   - VLAN 50: Zona Desmilitarizada (DMZ) para servicios públicos.
   - VLAN 60: Wi-Fi para Invitados (aislamiento total de la red interna).
4. **Pilar Aplicaciones:** Inspección continua de tráfico web a través de un Web Application Firewall (WAF) perimetral, transición obligatoria hacia TLS 1.3 con desactivación de suites criptográficas heredadas y endurecimiento (*hardening*) del servidor Nginx.
5. **Pilar Datos:** Cifrado integral de bases de datos tanto en reposo (AES-256) como en tránsito (TLS 1.3), complementado con la aplicación estricta del principio de mínimo privilegio en el acceso a tablas.

Sec 10.2 Matriz de Roles, Usuarios y Permisos (RBAC / Zero Trust)

Rol Institucional	Identidades	Ámbito de Acceso Autorizado	Controles Obligatorios
Super Administrador	Personal OTI designado	Consolas de administración, Switch Core y servidores	MFA físico (FIDO2), acceso solo por IP estática y bastion host
Docente	Docentes ordinarios y contratados	Módulo docente del SIA y Campus Virtual institucional	MFA por TOTP, expiración de sesión a 15 min de inactividad
Estudiante	Alumnos matriculados	Consulta de notas, matrícula web y Campus Virtual	Credencial única, captcha y límite de intentos fallidos
Administrativo	Personal de tesorería y mesa de partes	SITRAD y sistemas de recaudación específicos	Acceso restringido a VLAN 20 y horario laboral institucional

MARCO GENERAL DE CIBERSEGURIDAD NIST CSF 2.0

En este capítulo se aborda el gobierno de la ciberseguridad universitaria bajo el estándar internacional **NIST Cybersecurity Framework 2.0**, integrando sus seis funciones fundamentales.

Sec 11.1 Las Seis Funciones Fundamentales del NIST CSF 2.0 en la UNAP

1. **GOVERN (Gobernar):** Establecimiento y difusión de directivas institucionales de seguridad digital, designación formal del Oficial de Seguridad de la Información (CISO), asignación presupuestal específica y alineamiento con la normativa del Estado Peruano (D.U. N° 006-2020).
2. **IDENTIFY (Identificar):** Catalogación y actualización continua del inventario de activos, evaluación sistemática de riesgos informáticos y análisis de impacto en la operación académica universitaria.
3. **PROTECT (Proteger):** Hardening de servidores Nginx, publicación forzada de cabeceras HSTS, configuración de registros SPF estricto (`-all`) y DMARC (`p=reject`), y adopción de autenticación multifactor (MFA).
4. **DETECT (Detectar):** Monitoreo operacional 24/7 mediante la plataforma SIEM centralizada (Wazuh), correlación de anomalías, alertas automáticas por fuerza bruta y recolección inmutable de registros de eventos.
5. **RESPOND (Responder):** Protocolos y playbooks operativos para contención inmediata, aislamiento automático de subredes comprometidas y comunicación institucional con el CSIRT Nacional de la PCM.
6. **RECOVER (Recuperar):** Políticas de respaldo bajo el esquema 3-2-1 con copias de seguridad inmutables fuera de línea (*Air-Gapped*) y ensayos periódicos semestrales de restauración de bases de datos.

Sec 11.2 Matriz NIST CSF 2.0 de la UNAP

Función NIST	Acción Estratégica	Responsable	Herramientas / Controles
GOVERN	Políticas y directivas de seguridad	Rectorado / CISO	Comité de Gobierno Digital y normativas
IDENTIFY	Inventario continuo y matriz de riesgos	Unidad de Seguridad	crt.sh, Nessus y matriz de activos
PROTECT	Hardening web, MFA y DMARC	OTI / Redes	Nginx, Let's Encrypt, TOTP, DNS BIND

Función NIST	Acción Estratégica	Responsable	Herramientas / Controles
DETECT	Monitoreo continuo de eventos y logs	CSIRT-UNAP	Wazuh SIEM, Suricata IDS y Syslog
RESPOND	Playbooks de contención de incidentes	CSIRT-UNAP	Procedimientos formales y scripts de aislamiento
RECOVER	Restauración de respaldos 3-2-1	OTI / Soporte	Almacenamiento Air-Gapped y Veeam Backup

CONTROLES TÉCNICOS DE SEGURIDAD

En este capítulo se detallan las especificaciones técnicas y el catálogo de implementación de los controles de seguridad seleccionados para blindar el entorno tecnológico de la UNAP.

Sec 12.1 Catálogo de Especificación Técnica de Controles

1. **Control de Identidad y Acceso:** Implementación generalizada de Autenticación Multifactor (MFA) sobre un esquema de Inicio de Sesión Único (Single Sign-On - SSO) corporativo basado en OpenID Connect / SAML 2.0.

2. **Seguridad Perimetral y de Aplicación:** Despliegue de un Firewall de Siguiente Generación (Next-Generation Firewall - NGFW) en el borde y un Web Application Firewall (WAF) perimetral para inspección de peticiones HTTP/HTTPS (bloqueo de inyecciones SQL, XSS y ataques L7).

3. **Seguridad en Endpoints:** Instalación de agentes de Endpoint Detection and Response (EDR) centralizados en todas las estaciones administrativas y servidores del Data Center para detección de comportamientos anómalos.

4. **Cifrado Criptográfico Estricto:** Forzado del protocolo TLS 1.3 en todos los portales web institucionales, desactivación definitiva de suites criptográficas débiles (SSLv3, TLS 1.0, TLS 1.1) y cifrado de volúmenes de almacenamiento mediante LUKS / BitLocker.

5. **Monitoreo y Auditoría Centralizada:** Plataforma SIEM (Security Information and Event Management) basada en Wazuh para agregación, correlación y análisis de registros de eventos en tiempo real.

6. **Microsegmentación de Redes:** Reglas estrictas de filtrado de tráfico inter-VLAN en el Switch Core central, impidiendo que el tráfico de alumnos acceda a servidores de bases de datos o redes administrativas.

7. **Gestión Continua de Vulnerabilidades:** Ejecución de escaneos periódicos programados mediante OpenVAS / Nessus para identificación y remediación temprana de fallas en servidores y servicios expuestos.

8. **Continuidad Operativa y Respaldos Inmutables:** Automatización de copias de seguridad de bases de datos con retención histórica y almacenamiento inmutable fuera de línea.

Sec 12.2 Configuración de Endurecimiento Web en Servidores Nginx

A continuación, se presenta la directiva de configuración recomendada para mitigar los hallazgos de información expuesta y falta de HSTS:

>_ | Configuración Nginx para Hardening (security.conf)

```
# Desactivar version de servidor
server_tokens off;

# Cabeceras de proteccion obligatorias
add_header Strict-Transport-Security 'max-age=31536000; includeSubDomains'
    always;
add_header X-Frame-Options 'SAMEORIGIN' always;
add_header X-Content-Type-Options 'nosniff' always;
add_header X-XSS-Protection '1; mode=block' always;
add_header Content-Security-Policy 'default-src \'self\';' always;

# Forzar TLS 1.2 y 1.3 unicamente
ssl_protocols TLSv1.2 TLSv1.3;
ssl_prefer_server_ciphers on;
```

GESTIÓN Y RESPUESTA A INCIDENTES

En este capítulo se describe el procedimiento operativo estándar para la gestión, contención y recuperación ante eventos o incidentes de seguridad que afecten a la UNAP.

Sec 13.1 Procedimiento Operativo Estándar

El ciclo de vida de atención a incidentes de seguridad digital sigue la secuencia estándar de seis fases:

Detección $\longrightarrow$ **Análisis y Triaje** $\longrightarrow$ **Contención**
$\longrightarrow$ **Erradicación** $\longrightarrow$ **Recuperación** $\longrightarrow$ **Evaluación Post-Mortem**

1. **Detección:** Identificación de alertas a través del SIEM, reportes de usuarios o anomalías en el tráfico de red.
2. **Análisis y Triaje:** Determinación del alcance, impacto potencial y severidad del incidente por parte del equipo CSIRT-UNAP.
3. **Contención:** Aplicación de medidas de aislamiento inmediato (aislamiento de VLAN, revocación de tokens, bloqueo perimetral de IPs) para evitar la propagación.
4. **Erradicación:** Eliminación de artefactos maliciosos, cierre de brechas de configuración y revocación de credenciales comprometidas.
5. **Recuperación:** Restauración de servicios a partir de respaldos limpios validados y reactivación paulatina con monitoreo reforzado.
6. **Evaluación Posterior (Post-Mortem):** Elaboración del informe técnico final, identificación de lecciones aprendidas y ajuste de controles preventivos.

Sec 13.2 Canales Institucionales de Notificación Rápida

Para garantizar la oportuna recepción de reportes sobre comportamientos anómalos, se formalizan los siguientes canales oficiales:

- **Correo Electrónico de Seguridad:** `seguridad.informatica@unap.edu.pe`
- **Anexo Telefónico de Emergencia OTI:** Anexo interno 1111 (Línea directa del CSIRT-UNAP).
- **Botón de Reporte en Webmail:** Complemento integrado en el correo institucional para notificar mensajes sospechosos de phishing en un clic.

Sec 13.3 Clasificación de Incidentes por Tipo de Amenaza

- **Phishing Masivo o Dirigido:** Correos fraudulentos que buscan robar identidades o distribuir malware.
- **Accesos No Autorizados:** Intentos de inicio de sesión anómalos o explotación de credenciales institucionales.
- **Infecciones por Malware / Ransomware:** Ejecución de código malicioso en servidores o computadoras de oficinas.
- **Exfiltración de Información:** Fuga o extracción no autorizada de bases de datos o expedientes sensibles.

13.3. CLASIFICACIÓN DE INCIDENTES POR TIPO DE AMENAZA

- **Pérdida o Sustracción de Equipos Físicos:** Extravío de portátiles o almacenamiento institucional con datos sensibles.

CAPACITACIÓN Y CONCIENTIZACIÓN

En este capítulo se establece el programa integral de concientización y formación en seguridad digital para toda la comunidad universitaria.

Sec 14.1 Campaña Permanente de Concientización

Se implementará un plan continuo de sensibilización enfocado en mitigar el factor humano como vector de ataque:

- **Ingeniería Social y Phishing:** Talleres prácticos para reconocer correos apócrifos, enlaces sospechosos y técnicas de manipulación psicológica.
- **Contraseñas Robustas y Gestión de Identidad:** Uso de contraseñas de alta entropía, adopción de gestores de contraseñas y activación obligatoria de MFA.
- **Manejo Seguro de Medios Extraíbles (USB):** Protocolos para evitar la conexión de dispositivos USB desconocidos en computadoras institucionales.
- **Navegación Segura y Protección de Datos:** Pautas para identificar certificados HTTPS válidos y evitar el ingreso de credenciales en redes Wi-Fi públicas.

Sec 14.2 Simulaciones Semestrales de Phishing Controlado

La OTI ejecutará ejercicios semestrales de simulación de phishing no destructivo hacia el personal docente y administrativo, con el objetivo de medir la susceptibilidad institucional, capacitar en tiempo real a los usuarios que caigan en el señuelo y evaluar la tasa de reporte voluntario.

Sec 14.3 Módulos de Formación Especializada para Personal Técnico

Dirigidos a los administradores de sistemas, redes y desarrolladores de software de la OTI:

- **Desarrollo Seguro de Software (OWASP Top 10):** Técnicas de codificación defensiva, sanitización de entradas, prevención de inyecciones SQL/XSS y validación de APIs REST.
- **Hardening de Infraestructura:** Configuración segura de servidores web Nginx/Apache, bastionado de sistemas operativos Linux y gestión segura de bases de datos.
- **Análisis de Logs y Cacería de Amenazas (Threat Hunting):** Uso avanzado de consolas SIEM para la identificación de anomalías y respuesta a intrusiones.

En este capítulo se establecen las métricas e Indicadores Clave de Desempeño (KPIs) para evaluar cuantitativamente la eficacia, madurez y avance del plan de ciberseguridad.

Sec 15.1 Cuadro de Mando de Métricas de Ciberseguridad

Los siguientes indicadores serán reportados trimestralmente al Comité de Gobierno Digital de la UNAP:

Indicador / Métrica	Fórmula de Cálculo	Meta Esperada	Frecuencia
Porcentaje de activos inventariados	$\frac{\text{Act. Catalogados}}{\text{Act. Totales}} \times 100$	$\geq 98\,\%$	Mensual
Cobertura de evaluación STRIDE	$\frac{\text{Sist. Modelados}}{\text{Sist. Críticos}} \times 100$	$100\,\%$	Semestral
Remediación de fallas críticas	Tiempo promedio de resolución de hallazgos	< 72 horas	Continuo
Cuentas con MFA activo	$\frac{\text{Cuentas con MFA}}{\text{Total Cuentas}} \times 100$	$100\,\%$	Mensual
Tasa de clics en phishing	$\frac{\text{Clics Phishing}}{\text{Total Evaluados}} \times 100$	$\leq 8\,\%$	Semestral
Tiempo medio de detección (MTTD)	Promedio de horas transcurridas desde el evento	< 2 horas	Mensual
Tiempo medio de respuesta (MTTR)	Promedio de horas para contención efectiva	< 4 horas	Mensual
Éxito en restauración de backups	$\frac{\text{Ensayos Exitosos}}{\text{Total Ensayos}} \times 100$	$100\,\%$	Semestral

En esta sección se compilan las matrices técnicas, evidencias operativas y formatos de gestión que sustentan el plan de ciberseguridad.

Sec Anexo 1: Inventario de Activos (Mapeo OSINT)

Tabla consolidada de los subdominios y servidores identificados mediante fuentes abiertas (`crt.sh` y DNS):

Subdominio Identificado	Dirección IP	Registro SSL / Origen	Estado Operativo
`matricula.unap.edu.pe`	161.132.24.61	Let's Encrypt Authority	Activo (Producción)
`campus.unap.edu.pe`	161.132.24.62	Let's Encrypt Authority	Activo (Producción)
`sitrad.unap.edu.pe`	161.132.24.63	cPanel / Sectigo SSL	Activo (Administrativo)
`repositorio.unap.edu.pe`	161.132.24.64	GlobalSign Root CA	Activo (Académico)
`dev.unap.edu.pe`	161.132.24.70	Certificado autofirmado	Riesgo (Entorno Dev)
`prue1.unap.edu.pe`	161.132.24.71	Certificado expirado	Riesgo (Entorno Legado)

Sec Anexo 2: Matriz de Criticidad de Activos (Tríada CIA)

Calificación de impacto institucional basada en Confidencialidad (C), Integridad (I) y Disponibilidad (A):

Activo Tecnológico	Confidencialidad	Integridad	Disponibilidad	Nivel Consolidado
Base de Datos Central	Muy Alto	Muy Alto	Muy Alto	**Crítico**
Sistema de Matrícula	Alto	Muy Alto	Muy Alto	**Crítico**
Campus Virtual Moodle	Medio	Alto	Muy Alto	**Crítico**
Correo Institucional	Muy Alto	Alto	Alto	**Alto**
Portal Web de Facultades	Bajo	Medio	Medio	**Medio**

Sec Anexo 3: Matriz STRIDE y Evidencias Técnicas

- **Diagrama de Flujo de Datos (DFD Nivel 1):** Navegador Cliente ↔ Reverse Proxy Nginx ↔ Backend ASP.NET Core ↔ Base de Datos.

- **Captura de Cabeceras HTTP (DevTools F12):** Exposición pública de la versión del servidor web en `matricula.unap.edu.pe`:

>_ | Evidencia F12: Cabeceras HTTP en matricula.unap.edu.pe

```
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sat, 17 Oct 2026 15:20:00 GMT
Content-Type: text/html; charset=utf-8
Set-Cookie: .AspNetCore.Cookies=CfDJ8...; path=/; HttpOnly; SameSite=Lax
# NOTA: Ausencia de cabecera Strict-Transport-Security (HSTS desactivado)
# NOTA: La bandera 'Secure' no se encuentra forzada en todas las cookies
```

Sec Anexo 4: Matriz MITRE ATT&CK y Configuración de Reglas

Mapeo sistemático de técnicas adversarias y correspondencia con reglas de detección en el SIEM institucional Wazuh.

Sec Anexo 5: Cyber Kill Chain y Evidencias de Dominio

- **Flujograma del ataque en 7 etapas:** Reconocimiento → Armamento → Entrega → Explotación → Instalación → C2 → Objetivos.

- **Evidencia DNS de vulnerabilidad en correo institucional:**

>_ | Evidencia DNS: Registros DMARC y SPF en unap.edu.pe

```
$ host -t txt _dmarc.unap.edu.pe
Host _dmarc.unap.edu.pe not found: 3(NXDOMAIN)

$ host -t txt unap.edu.pe
unap.edu.pe descriptive text 'v=spf1 ip4:161.132.24.0/24 include:_spf.
    google.com ~all'
```

Sec Anexo 6: Matriz Zero Trust y Postura de Red

- **Negociación TLS en campus.unap.edu.pe:** Inspección de certificados que confirma ausencia de precarga HSTS.
- **Esquema de Microsegmentación:** Aislamiento de VLAN 10 (Servidores), VLAN 20 (Administración), VLAN 30 (Docencia), VLAN 40 (Alumnos) y VLAN 60 (Wi-Fi Invitados).

Sec Anexo 7: Registro de Incidentes (Boleta Formal)

Formato estandarizado para la notificación interna y reporte formal ante el CSIRT-UNAP con campos de fecha, reportante, activo afectado, criticidad y vector preliminar.

Sec Anexo 8: Cronograma Anual de Implementación

Plan de trabajo estructurado a 12 meses (Fase 1: Diagnóstico e inventario; Fase 2: Despliegue de MFA y WAF; Fase 3: Hardening y SIEM; Fase 4: Auditoría y simulaciones de phishing).

Sec Anexo 9: Cuadro de Mando de Indicadores

Matriz de seguimiento de KPIs operativos (MTTD < 2 h, MTTR < 4 h, $100\,\%$ de cuentas docentes con MFA).

Sec Anexo 10: Plan de Capacitación y Concientización

Calendario temático semestral de talleres para docentes, alumnos y módulos especializados para el equipo técnico de la OTI en OWASP Top 10.



Congreso de la Republica del Peru. Ley nro. 29733: Ley de proteccion de datos personales y su reglamento, 2011.

FIRST. Common vulnerability scoring system v3.1: Specification document, 2019.

Michael Howard and David LeBlanc. *Writing Secure Code*. Microsoft Press, Redmond, WA, 2nd edition, 2003.

Eric M Hutchins, Michael J Cloppert, and Rohan M Amin. Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1):80–106, 2011.

ISO/IEC. Iso/iec 27001:2022 information security, cybersecurity and privacy protection — information security management systems — requirements, 2022.

Loren Kohnfelder and Praerit Garg. The threats to our products. Technical report, Microsoft Corporation, 1999. Microsoft Interface Security Report.

J. D. Meier, Alex Mackman, Michael Dunner, Srinath Vasireddy, Ray Escamilla, and Anand Murukan. Improving web application security: Threats and countermeasures. Technical report, Microsoft Corporation, 2003.

NIST. Guide for conducting risk assessments. Technical report, NIST Special Publication 800-30 Revision 1, 2012.

NIST. Framework for improving critical infrastructure cybersecurity (version 1.1). Technical report, National Institute of Standards and Technology, 2018.

OWASP Foundation. Threat modeling cheat sheet. Technical report, Open Web Application Security Project, 2020.

OWASP Foundation. Owasp top 10: 2021 - the ten most critical web application security risks. Technical report, Open Web Application Security Project, 2021.

Karen Scarfone, Murugiah Souppaya, Amanda Cody, and Angela Orebaugh. Technical guide to information security testing and assessment. Technical report, NIST Special Publication 800-115, 2008.

Adam Shostack. *Threat Modeling: Designing for Security*. John Wiley & Sons, Indianapolis, IN, 2014.

William Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7th edition, 2018.

The MITRE Corporation. Mitre att&ck enterprise matrix for web applications, 2023.